HelaCart

Hardening Release - Change Report

Backend API (NestJS), web storefront / Seller Center / Admin (Next.js) and buyer mobile app (Flutter)

Date: 1 November 2026
Source: HelaCart-pre-dev.zip
Deliverable: HelaCart-hardened.zip

Read this first: verification status

All changes were written by reading the code carefully. They have **not** been compiled, linted, tested or run, because the work environment could not download npm or Flutter packages. Expect a round of small compile, lint and formatting fixes when you first build on your machine. The section "What you need to do before launch" lists the exact commands to run, in order.

1. Summary

An audit of HelaCart-pre-dev found gaps across all three apps. This release fixes all of them except the two items you asked to leave out:

- **Out of scope:** online payments (PayHere or similar) with seller payouts, and a real courier API integration.
- **Order lifecycle:** failed deliveries and parcels returned to the seller now have proper statuses, with stock put back. Admins can step in on any stuck order, and orders a seller never accepts are cancelled automatically.
- **Revenue integrity:** commission no longer depends on the seller alone. The buyer can confirm receipt, admins can mark orders delivered, and a product cannot be approved without a commission rate while commission is on.
- **COD fraud controls:** SMS OTP phone verification (Notify.lk), a limit on open COD orders per buyer, a maximum COD order value, and blocking of suspended shops.
- **Notifications:** email (Resend), SMS (Notify.lk) and push (Firebase Cloud Messaging). Each goes through a database outbox with retries, and users can turn channels off.
- **Platform:** seller suspension, owner-only shop actions, an admin audit log, account deletion and data export (PDPA No. 9 of 2022), app version control, a rate limiter that no longer blocks the site, logging and error handling, faster search, and CI for every app.
- **Web:** guest cart, correct return to the right page after sign-in, SEO (metadata, sitemap, structured data), error pages, security headers, caching, and Sinhala/Tamil for the core buyer flows.
- **Mobile:** real app icons and splash, release signing, push notifications, Crashlytics, account deletion, legal links, a fix for checkout getting stuck, deep links and sharing, Sinhala/Tamil, and a force-update screen.

Area	Files changed	Files added	Main new pieces
Backend API	73	49	3 migrations, 17 new endpoints, 2 new workers, 13 new test files
Web (storefront, seller, admin)	77	48	2 admin screens, 3 legal pages, i18n (en/si/ta), SEO, guest cart
Mobile (Flutter buyer app)	134	55	Push, Crashlytics, i18n (en/si/ta), icons, signing, new account screens
CI / docs	1	3	API and storefront workflows; shared API contract document

The shared contract that all three apps follow is `docs/API-CHANGES-2026-11.md`. Its last section, "Backend implementation notes", records the small places where the backend differs from the original plan.

2. Backend API (helacart-api)

Problem found	What was done	Main files
Failed or refused deliveries stayed SHIPPED forever; stock never came back; admins could only read orders.	New statuses DELIVERY_FAILED and RETURNED_TO_SELLER, all managed in one state machine. Stock is restored on cancel and on return. Every change stores a reason and time. New admin order actions (cancel, mark failed, mark returned, mark delivered) and a "needs attention" queue.	src/commerce/order-state.ts, commerce.service.ts, commerce.controller.ts
Orders a seller never accepted were never cancelled.	A worker cancels PLACED orders older than SELLER_ACCEPT_HOURS (default 48) and notifies the buyer and seller.	src/commerce/order-auto-cancel.worker.ts
Only the seller could mark an order delivered, which is also the only point where commission is earned.	The buyer can confirm receipt and admins can mark an order delivered. While the commission policy is on, a product cannot be approved without a rate (COMMISSION_RATE_REQUIRED); the rate can be set at approval. Bulk approval follows the same rule.	commerce.service.ts, catalog/catalog.service.ts, business-tools/bulk-tools.service.ts
The per-IP rate limiter would block the whole site (the storefront server uses one IP) and users behind carrier NAT.	Calls from the storefront server carry a secret header and skip the general limit. Signed-in users get their own bucket, with a 5x higher limit per IP. All limits can be set through env variables.	src/config/request-limit.guard.ts
No COD fraud controls.	SMS one-time codes (only a hash of the code is stored, compared in constant time, 5 attempts, 10-minute expiry, resend limits). Optional verified-phone requirement at checkout. Limit on open orders per buyer and a maximum COD order value. The cart lists blocking problems before checkout.	src/phone-verification/*, src/common/phone.ts, commerce.service.ts
Sellers could not be suspended.	Admins can list sellers and suspend or reinstate them, with a reason. A suspended shop disappears from the store and its orders are refused at checkout, but it can still fulfil existing orders.	src/sellers/seller-status.*
Managers had the same powers as shop owners.	Owner-only: delivery settings, shop profile, refunds, commission payments and receipts, and the team.	catalog.service.ts (requireSellerMember)
Notifications were in-app only.	Email (Resend), SMS (Notify.lk) and push (FCM). Delivery rows are written in the same transaction as the notification and sent by a worker with retries. Invalid device tokens are deleted. Users can set notification preferences and register devices.	src/notifications/*
No account deletion or data export (Play Store, App Store and PDPA).	GET /me/data-export and DELETE /me/account. Deletion is blocked while the user has open orders or owns a shop. Personal data is anonymised, accounting records are kept, and the Firebase user is deleted.	src/account/*
No admin audit trail.	An append-only audit log, protected by a database trigger. It covers order actions, seller status, product reviews, categories, the home banner, account access and commission rates.	src/audit/*
Every request made a Firebase call and a database write; the database connection pool was too small.	Verified tokens are cached for up to 60 s. The admin guard reuses the verified identity. The profile is only written when something changed. Pool size is configurable (default 10).	src/auth/firebase-auth.guard.ts, sellers/admin.guard.ts, auth.service.ts
Workers would run on every server and silently swallowed errors.	Each worker tick takes a Postgres advisory lock, so only one server runs it. Errors are logged. The unused reservation loop only runs if RESERVATIONS_ENABLED=true.	src/common/advisory-lock.ts and all *.worker / *-worker.service files

Problem found	What was done	Main files
No logging, request IDs or global error handling.	An x-request-id header on every response, JSON logs in production, and a global exception filter that turns database errors into safe 4xx responses and logs every 5xx.	src/common/*
Uploaded photos and ID documents kept their EXIF/GPS data; sellers could link any image URL.	Metadata is stripped from JPEG, PNG and WebP uploads in all 7 upload services (pure TypeScript). Product image URLs must point at your R2 domain.	src/media/strip-metadata.ts
Search scanned the whole table.	pg_trgm trigram indexes that match the search expressions, and a cap on page depth.	migrations/20261101020000_search_trigram_indexes
Smaller gaps.	Address editing and a default address. One pending seller application per user. Optional restocking when a return is resolved. Public "hello" route removed. Stricter env validation (https CORS in production; all-or-nothing provider settings). New /app-config endpoint.	commerce, sellers, after-sales, config, app-config
No API CI, a weak Dockerfile, no backup script.	New .github/workflows/api.yml: typecheck, lint, format, unit and e2e tests, and migrations applied to Postgres 17. The Dockerfile has a pinned base image, runs as non-root and has a health check. New npm run db:backup and a runbook section on backup and restore drills.	.github/workflows/api.yml, Dockerfile, scripts/backup-db.mjs, OPERATIONS-RUNBOOK.md

3. Web (helacart-storefront)

Problem found	What was done
Guests could not add to cart.	A guest cart stored in the browser. It is merged into the server cart after a verified sign-in, with a notice about any items that were capped or unavailable.
Sign-in sent everyone to /account.	Every sign-in link carries the page to return to. The allow-list now covers cart, checkout, orders, account, seller, products, shops and legal pages, and open redirects are still blocked.
A missing env variable silently shipped a demo store.	A production build fails if the API URL or the Firebase settings are missing, unless NEXT_PUBLIC_ALLOW_PREVIEW_BUILD=1.
No error, loading or 404 pages.	error.tsx, global-error.tsx, loading.tsx and not-found.tsx, plus error pages for the seller and admin areas.
No SEO; private pages could be indexed.	Product and shop pages get metadata, canonical URLs, OpenGraph/Twitter tags and Product JSON-LD, and a missing product or shop returns a real 404. Added sitemap.xml and robots.txt. Admin, seller, account, cart, checkout and auth pages are noindex.
Nothing was cached; too many token refreshes.	Public server-side requests are cached for 60 s (categories 300 s) and send the internal API token. Tokens are only force-refreshed after verification or once after a 401.
No security headers.	CSP, frame-ancestors none / X-Frame-Options DENY, nosniff, Referrer-Policy, Permissions-Policy, COOP, and HSTS on https.
English only.	A small typed i18n system with a language cookie and a switcher. The core buyer flows are in English, Sinhala and Tamil (497 keys each). Seller and admin stay in English.
Backend features with no screen.	Seller variant editing. COD reconciliation can be recorded again. Address editing and default address. Admin commission rate at product approval.
New contract features.	Buyer: new order statuses with reasons, "I received this order", cancel with reason, phone verification by SMS code, checkout error messages. Seller: delivery failed, re-attempt and returned actions; suspension banner; owner-only actions hidden from managers. Admin: order actions, a "needs attention" tab, /admin/sellers, /admin/audit-log. Account: notification settings, data download and account deletion.
No legal pages or app-link files.	/legal/privacy, /legal/terms and /legal/returns (starter text; sections for your lawyer to review are marked). Also /.well-known/assetlinks.json and apple-app-site-association templates.
No CI; leftover template files.	New .github/workflows/storefront.yml. Removed unused template SVGs and stray byte-order marks, and added a Node engines field. README and Stitch docs updated.

4. Mobile (helacart_buyer_mobile_app)

Problem found	What was done
Launcher and App Store icons were plain white; default splash.	All icons generated from the HelaCart logo: Android mipmaps, round and adaptive (with a themed layer), notification icon, iOS icons without transparency, web icons. Branded splash screens, including Android 12+ and dark mode.
No release signing; debug builds only.	Release signing from key.properties, with code and resource shrinking and ProGuard rules. Falls back to debug signing with a warning if there is no keystore. Version is now 1.1.0+2.
No account deletion, privacy policy or terms (store requirements).	Delete my account (type DELETE to confirm) and Download my data. Privacy, terms and returns links in the account screen, the drawer and sign-in/sign-up; the URLs come from /app-config.
Missing Firebase settings silently turned sign-in off.	Release builds show the "Check app configuration" screen. Added config/prod.example.json and documented the flutterfire configure steps.
Checkout could get stuck in a loop.	A "Start over" action with a warning and a link to My orders. A saved attempt is also cleared on 403/422 and when secure storage can't be read. Android backup is turned off with data-extraction rules.
No push notifications or crash reporting.	Firebase Cloud Messaging: the device is registered on sign-in and on token refresh, and unregistered on sign-out. In-app banners while the app is open, and tapping a notification opens the right screen. The 60 s polling now only runs as a fallback. Crashlytics in release builds, with only the Firebase uid attached.
Deep links broke on the usual URL form; no sharing.	helacart://products/x, helacart:///products/x and https://helacart.lk/products/x all work, with a verified Android App Link and iOS Associated Domains. Share buttons on product and shop screens.
English only.	English, Sinhala and Tamil for the core flows (506 keys each). The language is saved and can be changed in the account screen or the drawer.
New contract features.	Order statuses with reasons, I received this order, cancel with reason (only while PLACED). Address editing, default address, phone-verified badge and SMS code screen. Checkout error codes and blockers. Notification preferences. Force-update screen and optional-update banner. "Sell on HelaCart" link.
Uneven UX.	Pull-to-refresh on every list. Lists no longer flash the loading skeleton on refresh. Profile builds enforce HTTPS like release builds.
Template leftovers and thin CI.	Removed the unused linux, windows and macos folders and moved MainActivity to the right package; the app name is now HelaCart. CI gained a signed app-bundle job (runs when the secrets exist) and an iOS no-codesign build.

New Flutter packages (you need to run `flutter pub get` and commit pubspec.lock):

Package	Version constraint	Used for
`firebase_messaging`	`>=16.0.0 <19.0.0`	Push notifications
`firebase_crashlytics`	`>=5.0.0 <7.0.0`	Crash reporting
`share_plus`	`^13.2.0`	Sharing products, shops and the data export
`package_info_plus`	`^10.2.0`	App version for the force-update check
`url_launcher`	`^6.3.2`	Legal links, store links, Sell on HelaCart
`path_provider`	`^2.1.5`	Temporary file for the data export
`flutter_localizations`	`SDK`	Sinhala/Tamil Material localisations

5. New and changed API endpoints

All under /api/v1. Admin routes use AdminGuard; /me routes require a signed-in user.

Method and path	Purpose
`PATCH /sellers/:id/orders/:soId/status`	Changed: adds DELIVERY_FAILED, RETURNED_TO_SELLER and re-ship; reason required for cancel, failed and returned
`PATCH /me/orders/:id/seller-orders/:soId/cancel`	Changed: optional { reason }; still allowed only while PLACED
`POST /me/orders/:id/seller-orders/:soId/confirm-receipt`	Buyer confirms delivery and COD payment (earns commission)
`POST /admin/orders/:soId/actions`	Admin CANCEL, MARK_DELIVERY_FAILED, MARK_RETURNED or MARK_DELIVERED, with a reason
`GET /admin/orders/attention`	Stuck shipments, failed deliveries and orders close to auto-cancel
`PATCH /admin/products/:id/approve`	Changed: optional { commissionRateBps }; COMMISSION_RATE_REQUIRED
`POST /me/phone-verifications`	Send an SMS one-time code
`POST /me/phone-verifications/:id/confirm`	Check the code
`GET /me/verified-phones`	List the user's verified phone numbers
`PATCH /me/addresses/:id`	Edit an address or make it the default
`GET /admin/sellers`	Seller list with status, product and open-order counts
`PATCH /admin/sellers/:id/status`	Suspend or reinstate a seller
`POST /me/devices, POST /me/devices/unregister`	Register or remove a push device token
`GET / PUT /me/notification-preferences`	Turn push, email and SMS on or off
`GET /me/data-export`	Download all of my data as JSON
`DELETE /me/account`	Delete and anonymise my account ({ confirm: "DELETE" })
`GET /app-config`	Minimum and latest app versions, store links, legal and support links
`GET /admin/audit-log`	Admin audit trail
`GET /api/v1/ (removed)`	Public hello route removed

Machine-readable error codes (in the code field of error responses): PHONE_INVALID, OTP_RATE_LIMITED, OTP_INVALID, OTP_EXPIRED, PHONE_NOT_VERIFIED, TOO_MANY_OPEN_ORDERS, COD_LIMIT_EXCEEDED, SELLER_SUSPENDED, OWNER_ONLY, COMMISSION_RATE_REQUIRED, ACCOUNT_HAS_OPEN_ORDERS, ACCOUNT_OWNS_SHOP, IMAGE_URL_NOT_ALLOWED, ORDER_TRANSITION_NOT_ALLOWED, APPLICATION_ALREADY_PENDING.

6. New environment variables

Variable	Default / example	Notes
DATABASE_POOL_SIZE	10	Prisma connections per API process
AUTH_TOKEN_CACHE_SECONDS	60	How long a verified Firebase token is cached
LOG_LEVEL	info	JSON logs in production
INTERNAL_API_TOKEN	(32+ chars)	Required in production; same value as HELACART_INTERNAL_API_TOKEN in the storefront
RATE_LIMIT_GENERAL / WRITE / CONTENT_PER_MINUTE	180 / 20 / 30	Per-bucket limits
RATE_LIMIT_AUTHENTICATED_IP_MULTIPLIER	5	Per-IP ceiling for signed-in users
SELLER_ACCEPT_HOURS	48	Auto-cancel window for unaccepted orders
MAX_OPEN_COD_ORDERS	5	Open seller orders allowed per buyer
MAX_COD_ORDER_LKR_MINOR	50000000	LKR 500,000
REQUIRE_PHONE_VERIFICATION	false	Set true once SMS is live
NOTIFY_LK_USER_ID / API_KEY / SENDER_ID	-	SMS (all or none)
OTP_SECRET	-	HMAC secret for codes; required when SMS is on
RESEND_API_KEY / RESEND_FROM	-	Email (all or none)
PUSH_NOTIFICATIONS_ENABLED	true	FCM through the existing firebase-admin setup
RESERVATIONS_ENABLED	false	Unused stock-reservation expiry loop
APP_ANDROID_* / APP_IOS_* (MIN_VERSION, LATEST_VERSION, STORE_URL)	1.0.0	Force-update and update banner
APP_WEB_BASE_URL, LEGAL_*_URL, SUPPORT_EMAIL, SUPPORT_PHONE	https://helacart.lk/...	Returned by /app-config
NEXT_PUBLIC_SITE_URL (web)	https://helacart.lk	Canonical URLs, sitemap, OpenGraph
NEXT_PUBLIC_ALLOW_PREVIEW_BUILD (web)	-	Set to 1 only to build the demo preview
HELACART_INTERNAL_API_TOKEN (web, server-only)	-	Sent as x-helacart-internal
HELACART_IMAGE_ORIGINS (web)	-	R2 image origin(s) for CSP and next/image

7. Database migrations

Migration	Contents
20261101000000_hardening_enum_values	New enum values only: DELIVERY_FAILED, RETURNED_TO_SELLER, SELLER_STATUS_CHANGED, account status DELETED. These are in their own file because Postgres can't use a new enum value in the same transaction that adds it.
20261101010000_hardening_release	Order status reason and time (backfilled); nullable event actor and event reason; seller status reason; default address; phone verification tables; notification outbox, device tokens and preferences; append-only admin audit log.
20261101020000_search_trigram_indexes	pg_trgm extension and GIN trigram indexes for catalog search.

Apply with `npm run db:deploy`. Never use `migrate reset` on a real database. Back up first (`npm run db:backup`).

8. Independent review

A separate reviewer who had not written the code read the backend changes looking for compile-time, migration and production defects. It fixed these:

- Long notification batches could outlive the advisory lock's transaction, so two servers could send the same SMS or email twice. Each worker tick now has a 150-second budget and stops sending before the lock is released.
- The rate limiter created a map entry before it checked the per-IP limit, so forged tokens could flood the map and reset the limit. The per-IP bucket is now checked first.
- Very long push device tokens could exceed the Postgres index size and return a 500. Tokens are now limited to 2,048 printable ASCII characters.
- Removing a default address could race with adding or editing one. It now takes the same per-user row lock as add and edit.
- Lead follow-up: the verified-token cache is no longer used on admin routes, so a revoked admin session stops working immediately.
- Lead follow-up: the open-order limit now also counts the seller orders that the current checkout would create.
- Lead follow-up: buyers can only cancel while the order is PLACED, which is the original business rule.

Items it flagged but did not change (check these):

- Each worker tick holds one database connection. Check DATABASE_POOL_SIZE (default 10) against your Neon connection limit.
- Notification delivery is at-least-once: a crash between sending and recording can send a message again.
- Setting isDefault: false on the default address leaves the user with no default address.
- The trigram indexes are built without CONCURRENTLY, so writes to Product, Seller and Category are blocked briefly while the migration runs. Run it at a quiet time.
- A failed SMS send still counts toward the OTP resend limits.

9. What you need to do before launch

Backend (Node 24.15+ and PostgreSQL)

- `cd helacart-api && npm ci && npm run check`. Fix any compile, lint or formatting issues; generated Prisma types are the most likely source.
- Back up the database (`npm run db:backup`), then `npm run db:deploy` and `npm run db:status`. Try it on a Neon branch first.
- Add the new env variables (section 6). Create Notify.lk and Resend accounts and set OTP_SECRET and INTERNAL_API_TOKEN.
- On the first deploy the auto-cancel worker will cancel any PLACED orders older than 48 hours. Clear or accept old test orders first.
- Test SMS, email and push with real accounts. Turn on REQUIRE_PHONE_VERIFICATION once SMS works.
- Make sure the node:24.19.0-bookworm-slim Docker tag exists, or change the pin to an existing 24.x tag.

Web

- `cd helacart-storefront && npm ci && npm run lint && npx tsc --noEmit && npm run build`.
- Set NEXT_PUBLIC_SITE_URL, HELACART_INTERNAL_API_TOKEN and HELACART_IMAGE_ORIGINS. Check that Firebase sign-in works under the new Content-Security-Policy.
- Replace the SHA-256 fingerprint and Apple Team ID placeholders in public/.well-known.
- Have the legal pages (privacy, terms, returns) reviewed and filled in. They are starter text.

Mobile

- `flutter pub get`, then `dart format lib test tool`, `flutter analyze` and `flutter test`. Commit the new pubspec.lock.
- `flutterfire configure` for Android and iOS (creates google-services.json and GoogleService-Info.plist), and upload an APNs key to Firebase.
- Create the upload keystore and android/key.properties, and add the keystore secrets to GitHub for the release job.
- In Xcode, turn on Push Notifications, Background Modes (remote notifications) and Associated Domains for the App ID.
- Confirm the Crashlytics Gradle plugin version (3.0.6) and the FlutterFire package versions that pub picks.

10. Still not done

- **Out of scope:** online payments with seller payouts, and courier API integration.
- Swagger/OpenAPI docs. The shared contract document is the reference for now.
- A Redis-backed rate limiter and cache. Limits are still counted per process, so with several replicas each one counts separately.
- Sinhala/Tamil for the seller and admin areas, legal page bodies, and a few secondary buyer screens (reviews, returns, support, profile forms).
- Seller-side return resolution with restocking. Restocking is currently an admin action only.
- Deleted buyers' names stay on their past reviews, because an existing database rule forbids changing them.
- A seller or admin mobile app.